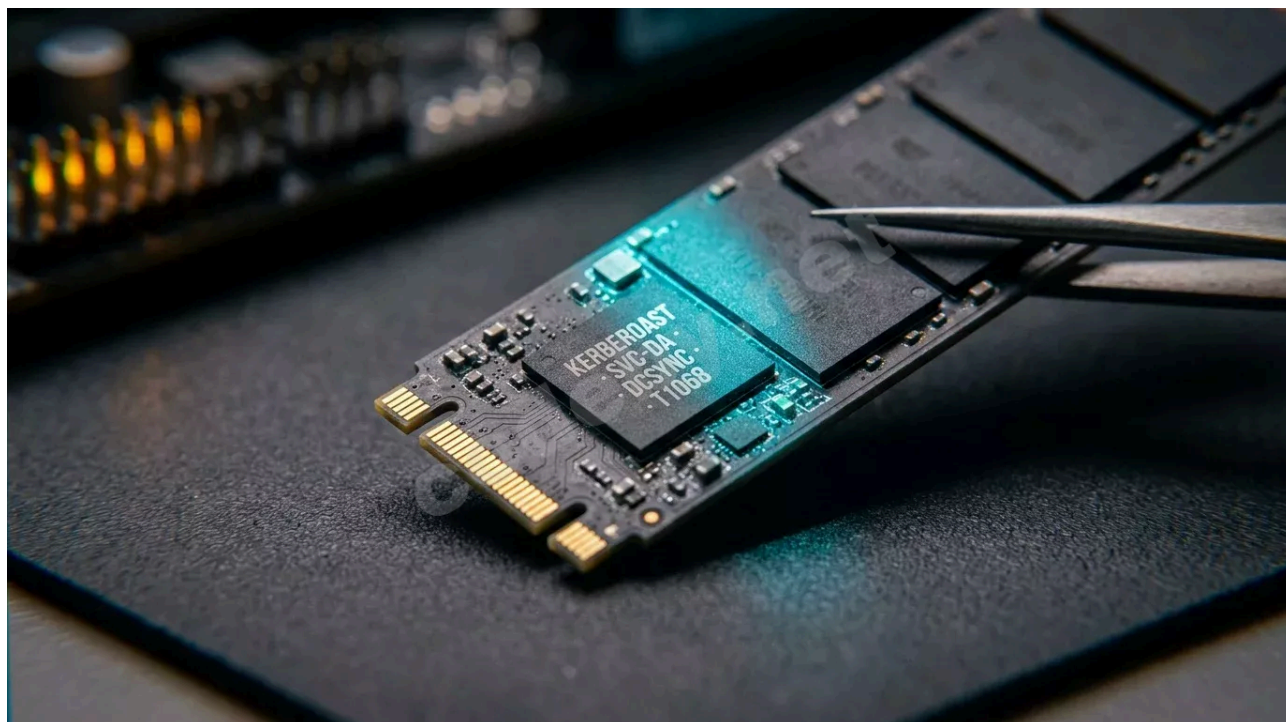


Статья Домашняя лаборатория Active Directory для пентеста: от развёртывания до первой атаки на домен

 codeby.net/threads/domashnyaya-laboratoriya-active-directory-dlya-pentesta-ot-razvertyvaniya-do-pervoi-ataki-na-domen.95155

August 14, 2026

[Добавить закладку](#)



На последнем внутреннем пентесте цепочка заняла четыре часа: Kerberoasting сервисного аккаунта с правами Domain Admin, офлайн-перебор хеша за двенадцать минут, DCSync - и полный контроль над лесом из 1200 хостов. Три мiskonфигурации, каждая из которых "точно не критична" по мнению админов. Знакомо?

Чтобы отрабатывать такие цепочки без риска для чужой инфраструктуры, нужна домашняя лаборатория Active Directory для пентеста. Не чистый домен из коробки, а среда с намеренно заложенными ошибками конфигурации - теми самыми, которые встречаются в каждой второй корпоративной сети. Дальше - пошаговый маршрут: от промоушна контроллера домена до первого захвата DA на собственном полигоне.

Требования к окружению для виртуальной сети с Active Directory

Аппаратные ресурсы:

Компонент	Минимум	Рекомендуется
RAM	16 ГБ	32 ГБ
CPU	4 ядра, VT-x / AMD-V включён в BIOS	8 ядер
Диск	SSD, 150 ГБ свободных	NVMe 256+ ГБ
Гипервизор	VirtualBox 7.x / VMware Workstation Pro 17	Proxmox VE 8.x на выделенном хосте

На 16 ГБ поместятся DC на Server Core (2 ГБ RAM), одна рабочая станция Windows 10 (4 ГБ), Kali (4 ГБ) - хосту останется около 6 ГБ. Server Core экономит прилично: потребление в покое 500-700 МБ вместо 2-4 ГБ у Desktop Experience. На 32 ГБ можно добавить второй DC для trust-отношений или файловый сервер с намеренно открытыми шарами.

Что скачать:

- Windows Server 2019/2022 Evaluation ISO - бесплатно на Microsoft Evaluation Center, 180 дней. Снапшот до истечения срока позволяет откатить таймер.
- Windows 10/11 Enterprise Evaluation - 90 дней, те же условия.
- Kali Linux - OVA для VirtualBox или VMX для VMware с kali.org/get-kali.

Сетевая топология:

Изолированная Host-Only сеть. В VMware - Custom VMnet на подсети 192.168.56.0/24. В VirtualBox - Host-Only Adapter. В Proxmox - Linux Bridge (vmbbr1) без привязки к физическому интерфейсу, чтобы трафик не утёк в домашнюю сеть.

Типовая адресация:

- 192.168.56.10 - DC01 (Windows Server 2022, контроллер домена, DNS)
- 192.168.56.20 - WKS01 (Windows 10/11, доменная рабочая станция)
- 192.168.56.99 - KALI (атакующая машина: Impacket, BloodHound, NetExec)

Статические IP на каждой VM. DNS рабочей станции указывает строго на IP контроллера домена. Без корректного DNS-резолвинга Add-Computer не найдёт

домен - это причина номер один провала при первой настройке. Я сам на это наступал, и каждый второй стажёр наступает тоже.

Развёртывание контроллера домена для пентеста через PowerShell

```
PS C:\WINDOWS\system32> Get-ADDomainController

ComputerObjectDN      : CN=(...),OU=Domain Controllers,...
DefaultPartition      : DC=...
Domain                : ...
Enabled               : True
Forest                : ...
HostName              : (... DC01.
InvocationId          : 9604...
IPv4Address            : 10.
IPv6Address           : ...
IsGlobalCatalog       : True
IsReadOnly            : False
LdapPort              : 389
Name                  : (... DC01
NTDSSettingsObjectDN  : CN=NTDS Settings,CN=... DC01,CN=Servers
OperatingSystem       : Windows Server 2008 R2 Standard
OperatingSystemHotfix : ...
OperatingSystemServicePack : Service Pack 1
OperatingSystemVersion : 6.1 (7601)
OperationMasterRoles   : {}
Partitions             : ...
ServerObjectDN        : ...
ServerObjectGuid       : 80557a88-... 31d6
Site                  : (... g
SslPort               : 636
```

Промоушн DC и установка AD DS

После установки Windows Server задайте статический IP через New-NetIPAddress, переименуйте машину командой Rename-Computer -NewName DC01 -Restart.

Отключите Windows Firewall: Set-NetFirewallProfile -Profile

Domain,Public,Private -Enabled False. В проде так делать нельзя, но в лабе файервол мешает чистоте эксперимента - будете потом час искать, почему Impacket не коннектится, а это просто порт закрыт. Опционально отключите Defender: Set-MpPreference -DisableRealtimeMonitoring \$true - чтобы инструменты не блокировались на этапе отладки.

Промоушн через PowerShell - быстрее GUI и воспроизводимо при пересборке:

```
Install-WindowsFeature -Name AD-Domain-Services -IncludeManagementTools
Import-Module ADDSDeployment
Install-ADDSForest `
  -DomainName "lab.internal" `
  -DomainNetbiosName "LAB" `
  -InstallDns:$true `
  -SafeModeAdministratorPassword `
    (ConvertTo-SecureString "DSRmpass2026!" -AsPlainText -Force) `
  -Force:$true
```

Сервер перезагрузится автоматически. Убедитесь, что домен поднялся: `Get-ADDomain | Select-Object Name, DomainMode, PDCEmulator`. Команда должна вернуть имя домена и роль PDC Emulator. Дополнительно проверьте лес: `Get-ADForest | Select-Object Name, ForestMode`.

Предусловия: Windows Server 2019 или 2022, Desktop Experience или Server Core. Для первого развёртывания Desktop Experience удобнее - есть GUI для Server Manager. Когда процесс станет привычным, переходите на Core ради экономии ресурсов.

Пользователи, организационные единицы и присоединение к домену

Плоский домен с тремя учётками бесполезен. В реальных сетях - десятки OU, вложенные группы, сервисные аккаунты с историей. Минимально реалистичная структура: 3-5 отделов, 5-8 пользователей в каждом.

Создайте корневую OU: `New-ADOrganizationalUnit -Name "Employees" -Path "DC=lab,DC=internal"`. Внутри - подразделения IT, Finance, HR через аналогичную команду. Для каждого пользователя: `New-ADUser -Name "it.user1" -SamAccountName "it.user1" -UserPrincipalName "it.user1@lab.internal" -Path "OU=IT,OU=Employees,DC=lab,DC=internal" -AccountPassword (ConvertTo-SecureString "Password1" -AsPlainText -Force) -Enabled $true`. Для массового создания - CSV и `Import-Csv | ForEach-Object { New-ADUser ... }` по аналогии с подходом, описанным в руководстве heartburn.dev.

Если пароли отклоняются доменной политикой - ослабьте её: `Set-ADDefaultDomainPasswordPolicy -Identity lab.internal -MinPasswordLength 1 -ComplexityEnabled $false`. Слабые пароли - именно то, что вы ищете на реальном пентесте, так что их имитация в лабе оправдана.

Присоединение WKS01 к домену: на Windows 10 задайте DNS через `Set-DnsClientServerAddress -InterfaceAlias "Ethernet" -ServerAddresses 192.168.56.10`, затем `Add-Computer -DomainName "lab.internal" -Credential (Get-Credential) -Restart`. После перезагрузки логин: `LAB\it.user1`.

установка AD CS командой `Install-WindowsFeature -Name ADCS-Cert-Authority -IncludeManagementTools` и настройка Enterprise Root CA через `Install-AdcsCertificationAuthority -CAType EnterpriseRootCa -Force` добавляют целый класс атак - ESC1-ESC8, связанных с шаблонами сертификатов. Если собираетесь

копать в эту сторону, AD CS ставьте сразу - потом доустанавливать на промотированный DC бывает капризно.

[Применимо: внутренний пентест, modern infrastructure Windows Server 2016+]

Снапшоты: сразу после настройки сделайте снапшот каждой VM - назовите "Baseline". Цикл "снапшот -> атака -> откат" экономит часы: пересобирать домен с нуля после деструктивного эксплойта не придётся.

Уязвимая AD инфраструктура для обучения: намеренные мисконфигурации



Чистый домен без ошибок конфигурации - бесполезный тестовый полигон для атак на домен. Ценность лабы - в мисконфигурациях, которые встречаются на каждом втором внутреннем пентесте.

Kerberoasting, AS-REP Roasting и делегирование

[Kerberoasting \(T1558.003, Credential Access\)](#)

[Применимо: внутренний пентест, Windows Server 2008+, legacy и modern]

Работает если: в домене есть пользовательский аккаунт с зарегистрированным SPN и слабым паролем. Не работает если: используются Group Managed Service Accounts (gMSA), пароль сервисного аккаунта длиннее 25 символов, или отключён RC4 для Kerberos (AES-only).

Механика простая: любой аутентифицированный доменный пользователь запрашивает TGS для аккаунта с SPN, получает тикет, зашифрованный NTLM-хешем пароля, и ломает его офлайн. Ни алертов, ни блокировок - по данным cryptus.in, эта техника присутствует в цепочке практически каждой крупной ransomware-атаки последних лет. И это логично: зачем шуметь, если можно тихо забрать тикет и уйти ломать к себе?

AS-REP Roasting

[Применимо: внутренний пентест, Windows Server 2008+]

Работает если: у целевого аккаунта отключена Kerberos Pre-Authentication (DONT_REQUIRE_PREAUTH). Не работает если: Pre-Authentication включена (по умолчанию - включена, поэтому встречается реже Kerberoasting).

Unconstrained Delegation

[Применимо: внутренний пентест, legacy-инфраструктура без перехода на Constrained/RBCD]

Работает если: компьютерному аккаунту назначен флаг TrustedForDelegation и удаётся закрепиться на этом хосте. Не работает если: применена Constrained Delegation или Resource-Based Constrained Delegation (RBCD).

Все три мисконфигурации настраиваются одним скриптом:

```
# Kerberoasting target
([URL='https://attack.mitre.org/techniques/T1558/003']T1558.003, Credential
Access[/URL])
```

```
New-ADUser -Name "svc_sql" -SamAccountName "svc_sql" `
  -AccountPassword (ConvertTo-SecureString "Summer2026!" -AsPlainText -Force) `
  -Enabled $true -PasswordNeverExpires $true
Add-ADGroupMember -Identity "Domain Admins" -Members "svc_sql"
setspn -A MSSQLSvc/db01.lab.internal:1433 svc_sql
# AS-REP Roasting target
Set-ADAccountControl -Identity "hr.user1" -DoesNotRequirePreAuth $true
# Unconstrained Delegation
Set-ADComputer -Identity "WKS01" -TrustedForDelegation $true
```

Сервисный аккаунт `svc_sql` с правами Domain Admin, статическим паролем и SPN - классика жанра. По данным RedFoxSec, одна из самых распространённых мiskonфигураций в enterprise-средах. На реальных проектах я видел такое десятки раз - и каждый раз админ уверен, что "этот аккаунт никто не знает".

ACL-мiskonфигурации и "фантомные" объекты

ACL-мiskonфигурации - самый тихий вектор. BloodHound находит путь через цепочку `GenericAll` на OU с привилегированными аккаунтами -> `WriteDacl` -> `DCSync`, о котором администратор даже не подозревает. Для лабы: выдайте пользователю из OU IT право `GenericAll` на OU Domain Admins через вкладку Security -> Advanced в ADUC.

"Фантомные" объекты - хитрость для экономии ресурсов: для атак Kerberoasting, ACL abuse и делегирования не нужен запущенный компьютер. Достаточно объекта Computer Account в AD. Создайте WEB-SRV01, SQL-SRV01, FILE-SRV01 через ADUC без запуска VM. Они потребляют 0 байт RAM, но участвуют в атаках на уровне Kerberos и LDAP. Назначьте WEB-SRV01 Unconstrained Delegation, зарегистрируйте SPN на SQL-SRV01 - и ваш домашний полигон для взлома Windows вместит реалистичный набор мiskonфигураций даже на 16 ГБ RAM.

Лаборатория для тестирования атак на AD: первая kill chain



Часть контента скрыта. Этот материал доступен участникам сообщества с рангом [One Level или выше](#)

Получить доступ просто — достаточно проявить активность на форуме

- дампы всех хешей домена. Вот и всё. От low-priv до полного контроля - три команды.

Полная цепочка: Initial Access (скомпрометированный `it.user1`) -> [Discovery \(BloodHound, T1087.002\)](#) -> [Credential Access \(Kerberoasting, T1558.003\)](#) -> Domain Dominance (`DCSync`).

Детекция: мониторьте Event ID 4769 для запросов Kerberos-тикетов с RC4-шифрованием от нетипичных аккаунтов. Это ключевой индикатор Kerberoasting.

LLMNR/NBT-NS Poisoning

[Применимо: внутренний пентест, legacy-инфраструктура без отключённого LLMNR]

Работает если: LLMNR и NBT-NS не отключены через GPO. Не работает если: применена GPO с Turn off multicast name resolution = Enabled, NetBIOS over TCP/IP отключён на сетевых адаптерах.

На Kali запустите responder -I eth0 -rdwv. На WKS01 обратитесь к несуществующему ресурсу - Responder перехватит Net-NTLMv2 хеш ([T1557.001, Name Resolution Poisoning and SMB Relay](#)). В лабе трафик генерируйте вручную: schtasks /create /tn "SimShare" /tr "net use \\FILESRV\Share" /sc daily /st 09:00 /ru "finance.user1". Когда имя FILESRV не резолвится через DNS, Windows отправит LLMNR-запрос - и Responder его перехватит.

GOAD как альтернатива ручной настройке лаборатории Active Directory

Game of Active Directory (GOAD) от Orange Cyberdefense разворачивает готовый AD-полигон через Vagrant. Варианты для разных бюджетов RAM:

Конфигурация	VM	Потребление RAM	Покрытие
MINILAB	2	~8 ГБ	DC + WKS, базовые атаки
GOAD-Light	3	~12 ГБ	DC + сервер + WKS, один домен
GOAD (полная)	5	~24 ГБ	Два леса, trust-отношения

Установка одной командой: git clone https://github.com/Orange-Cyberdefense/GOAD.git && cd GOAD && ./goad.sh -t install -l GOAD-Light -p virtualbox.

Когда GOAD недостаточен: GOAD даёт готовые мисконфигурации, но не учит понимать, **почему** одна строка setspn -А превращает аккаунт в точку входа. На реальном пентесте встретите конфигурацию, которой нет ни в одном GOAD-

сценарии - и тогда понимание протокола Kerberos на уровне механики станет критичным. GOAD - отличный старт, но не замена ручной сборки.

Сценарий grey box в домашней лабе для red team

На внутренних пентестах чаще выдают low-priv доменные креды, чем предлагают работать с нуля. Лаба позволяет отработать именно этот сценарий.

Чеклист при наличии доменных учётных данных (grey box):

1. BloodHound/SharpHound - визуализировать все пути до DA
2. Kerberoastable аккаунты: GetUserSPNs.py через Impacket
3. AS-REP Roastable: GetNPUsers.py lab.internal/ -usersfile users.txt -dc-ip 192.168.56.10
4. ACL-пути: в BloodHound запрос "Outbound Object Control" от текущего пользователя
5. GPP-пароли в SYSVOL: findstr /S /I cpassword \\lab.internal\sysvol*.xml
6. [LSASS на рабочей станции \(T1003.001, LSASS Memory\)](#) - если нет Credential Guard

Credential Guard на Windows 11: Mimikatz получает Access Denied даже с правами SYSTEM - VBS изолирует LSASS в виртуальном анклаве, недоступном даже для kernel-mode. По данным cryptus.in, это подтверждено на практике. На Windows 10 и Server 2019 без VBS Mimikatz работает штатно.

Альтернативные инструменты дампа LSASS из каталога LOLBAS: Comsvcs.dll через rundll32 C:\Windows\System32\comsvcs.dll, MiniDump <PID> dump.bin full - штатный компонент Windows, не требует сторонних бинарей. Также: adplus.exe (Windows Debugging Tools), Sqldumper.exe (Microsoft SQL), rdrleakdiag.exe - все перечислены в LOLBAS для [T1003.001](#). Формула на бумаге понятна, но дампы LSASS по-настоящему ощущаются только когда сам прогоняешь сценарий. На HackerLab.pro (<https://hackerlab.pro>) есть категории Active Directory и Forensics с задачами, которые покрывают эти техники на готовых стендах - удобно, когда лабу ещё не собрал, а руки уже чешутся.

Чем тестовый полигон отличается от симуляции корпоративной сети Windows

Нет EDR/SIEM: SharpHound, Mimikatz, Rubeus выполняются без единого алерта. На реальном пентесте CrowdStrike Falcon блокирует SharpHound по поведению, Kaspersky EDR Expert ловит Mimikatz через AMSI, Elastic 8.x+ детектирует массовые LDAP-запросы. Чтобы приблизить лабу к реальности - установите Sysmon

(Sysmon64.exe -accepteula -i sysmonconfig.xml), настройте форвардинг событий в ELK или Splunk. Для проверки детекции используйте [тесты из репозитория Atomic Red Team](#): для [T1003.001](#) есть готовые сценарии с ProcDump, Comsvcs.dll и direct system calls.

Плоская сеть: все VM в одном сегменте. В корпоративной среде между вами и DC - VLAN, ACL на сетевом оборудовании, jump-хосты. Для симуляции сегментации добавьте pfSense VM между подсетями.

Нет реального трафика: в пустом домене нет фоновых аутентификаций. Для LLMNR-атак и перехвата хешей трафик генерируется вручную через scheduled tasks.

Hardening-разрыв: реальные сети могут соответствовать требованиям DISA STIG (Microsoft Active Directory Domain STIG, Windows Server 2022 STIG), что существенно ограничивает атакующего. Лаба с отключённым файерволом и Defender - противоположность STIG-hardened среде. Учитывайте это при переносе навыков на боевые проекты.

Фактор	Лаба	Корпоративная сеть
EDR/AV	Отключен	CrowdStrike / Kaspersky / SentinelOne
Сетевая сегментация	Плоская	VLAN + ACL + jump-хосты
Количество хостов	3-5 VM	500-5000+
Аудит и логирование	Нет (пока не настроите Sysmon)	SIEM + audit policies

Я развернул несколько десятков таких полигонов - себе, стажёрам, коллегам из SOC, которые хотели понять атакующую сторону. Наблюдение, которое подтверждается раз за разом: пентестеры, начинавшие с GOAD и готовых лаб, на реальных проектах буксуют в нестандартных конфигурациях. Они знают, как запустить Rubeus, но не понимают, почему SPN делает аккаунт Kerberoastable на уровне протокола Kerberos. Ручная настройка домена с осознанным внесением каждой мiskonфигурации

формирует другой тип мышления - когда видишь новую сеть и сам определяешь, что искать, а не воспроизводишь шаблон из методички.

Второй момент - большинство AD-гайдов заканчиваются на развёртывании. "Вот DC, вот пользователи, вот Kerberoasting - удачи." Но реальный пентест - не набор изолированных техник, а цепочка, где каждое звено зависит от предыдущего. Что делать, если Kerberoasting не дал результата, потому что пароль оказался стойким? Переключаться на ACL-abuse. Делегирование оказалось constrained - искать RBCD. Эти развилки можно отработать только в собственной лабе, где вы контролируете сложность и знаете, какие именно мисконфигурации заложены.

Если после прочтения вы собрали DC, рабочую станцию и прошли цепочку от low-priv до DA - вы впереди большинства кандидатов на junior pentest. Следующая задача - второй лес с trust-отношениями и SID History abuse. На WAPT эту цепочку проходят в течение двух модулей с лабами.

Последнее редактирование модератором: